Attack Surface Reduction (ASR) Rules

Implementation Solution Guide

Version 1.0.0 · 2026-06-13

Contents

Executive Summary — Attack Surface Reduction (ASR) Rules (Microsoft Intune) 4

What you get . . . 4

What this delivers . . . 4

The standard deployment model . . . 4

Outcome . . . 4

1. Solution Overview — Attack Surface Reduction (ASR) Rules 4

What ASR rules are . . . 4

How rule modes work . . . 5

High-value rules this solution deploys . . . 5

How it works . . . 5

Benefits . . . 5

Limitations (be honest with buyers) . . . 6

The standard deployment model . . . 6

2. Requirements Guide — Attack Surface Reduction (ASR) Rules 6

2.1 Licensing . . . 6

2.2 Microsoft Defender Antivirus active . . . 6

2.3 Supported Windows OS . . . 6

2.4 Device enrollment . . . 6

2.5 (Recommended) Defender for Endpoint onboarding . . . 6

2.6 Application inventory (for exclusions) . . . 7

Checklist . . . 7

Global Requirements — Intune Solutions (category-level) 7

G1. Microsoft Entra ID tenant . . . 7

G2. Microsoft Intune subscription . . . 7

G3. Administrative roles . . . 7

G4. Device enrollment in Intune . . . 8

G5. Pilot security group . . . 8

G6. Supported Windows baseline . . . 8

G7. Network access to Microsoft cloud endpoints . . . 8

3. Implementation Guide — Attack Surface Reduction (ASR) Rules 8

Step 1 — Create the pilot group . . . 8

Step 2 — Create the ASR policy (Audit mode) . . . 8

Step 3 — Set the rules to Audit . . . 9

Step 4 — Assign and run the audit . . . 9

Step 5 — Review audit events . . . 9

Step 6 — Add exclusions . . . 9
Step 7 — Switch proven rules to Block . . . 9
Step 8 — Expand to production . . . 9
5. Testing Guide — Attack Surface Reduction (ASR) Rules 10
Test 1 — Policy applied . . . 10
Test 2 — Rules are in the expected mode . . . 10
Test 3 — Audit events are generated . . . 10
Test 4 — Block enforces (after switching) . . . 10
Test 5 — Exclusions work . . . 10
Test 6 — No business-app breakage . . . 10
Test 7 — Report review . . . 10
Pass/fail gate . . . 10
6. Troubleshooting Guide — Attack Surface Reduction (ASR) Rules 11
A. Rules not taking effect . . . 11
B. Legitimate app blocked . . . 11
C. Audit shows nothing during pilot . . . 11
D. Conflicts with other policies/baseline . . . 11
E. Diagnostics quick reference . . . 12
F. When to escalate . . . 12
7. Best Practices — Attack Surface Reduction (ASR) Rules 12
8. Deliverables Summary — Attack Surface Reduction (ASR) Rules 12
Documentation . . . 13
PowerShell scripts . . . 13
What the buyer receives . . . 13
Outcome . . . 13
Appendix A — PowerShell Scripts 14

Executive Summary — Attack Surface Reduction (ASR) Rules (Microsoft Intune)

White-label · Intune Solutions

Most malware uses the same handful of tricks: a macro spawning PowerShell, an email attachment launching an executable, credential theft from LSASS. **Attack Surface Reduction (ASR) rules** block those behaviors at the source — and managed through Microsoft Intune, you can roll them out safely in **Audit mode first**, review what *would* have been blocked, then enforce.

This is a complete, **deploy-it-today** package for implementing ASR rules with Microsoft Intune, written for an administrator with no prior ASR experience — including the audit-first method that prevents business-app breakage.

What you get

- A plain-language **Solution Overview** of what ASR rules block and how modes work.
- A **Requirements Guide** with verify / implement-if-missing for every prerequisite.
- An **Implementation Guide** of precise, click-by-click Intune steps in the required order.
- Five **PowerShell scripts** for posture discovery, rule validation, audit-event reporting, remediation, and a rule reference.
- **Testing** and **Troubleshooting** guides for confident rollout.

What this delivers

An Intune **Attack Surface Reduction policy** with the high-value rules (block Office child processes, block credential theft from LSASS, block executable content from email, block obfuscated scripts, and more) — deployed **Audit-first**, reviewed, then moved to **Block**, with exclusions.

The standard deployment model

Assess → Configure → Pilot → Validate → Expand.

Outcome

Behavior-based malware prevention across the fleet — rolled out without breaking line-of-business apps — deployable by a single administrator and validated before enforcement.

1. Solution Overview — Attack Surface Reduction (ASR) Rules

What ASR rules are

Attack Surface Reduction rules are behavior-based protections in Microsoft Defender that block the techniques malware commonly uses — regardless of the specific file. Rather than matching a known signature, each rule stops a *behavior* (for example, "an Office application creating a child process"). They are managed and reported through Microsoft Intune.

How rule modes work

Each rule can be set to:

- **Not configured** — the rule is off.
- **Audit** — the rule does **not** block, but logs what it *would* have blocked.
- **Block** — the rule enforces (blocks the behavior).
- **Warn** — blocks but lets the user bypass once.

> ***Method:*** *deploy in* ***Audit*** *first, review the events, then move proven rules to* ***Block*** *with any necessary exclusions. This is how you avoid breaking legitimate apps.*

High-value rules this solution deploys

- Block all Office applications from creating child processes.
- Block credential stealing from the Windows local security authority subsystem (**LSASS**).
- Block executable content from email client and webmail.
- Block execution of potentially obfuscated scripts.
- Block Office applications from injecting code into other processes.
- Block Win32 API calls from Office macros.
- Block process creations originating from PSExec and WMI commands.
- Use advanced protection against ransomware.

How it works

1. An Intune **ASR policy** sets each chosen rule to Audit or Block.
2. Defender Antivirus (real-time protection) enforces/audits the rules.
3. **Audit events** are logged locally (Defender Operational log) and surfaced in the Defender/ASR reports.
4. You review audit events, add **exclusions** for legitimate apps, then switch rules to **Block**.

Benefits

- **Behavior-based prevention** — stops whole classes of attack, not just known files.
- **Safe rollout** — Audit mode reveals impact before enforcement.
- **High ROI** — a few rules block the most common malware techniques.
- **Reportable** — audit/block events feed the ASR report and your SOC.

Limitations (be honest with buyers)

- Requires **Microsoft Defender Antivirus** active (real-time protection on).
- Some rules can affect legitimate apps — **Audit-first + exclusions** are essential.
- Full reporting is richest with **Defender for Endpoint** onboarded.
- Exclusions must be maintained as your app landscape changes.

The standard deployment model

> ***Create the ASR policy in Audit → review events → add exclusions → switch to Block → expand.***
> *repeatable pattern:* ***Assess → Configure → Pilot → Validate → Expand.***

2. Requirements Guide — Attack Surface Reduction (ASR) Rules

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites are in `global-requirements-intune-solutions.md`.

2.1 Licensing

Description: Intune (Plan 1). Defender for Endpoint enriches reporting (optional). **Why:** Intune delivers the ASR policy; MDE provides centralized ASR reporting/hunting. **Verify:** M365 admin center → **Billing** → **Licenses**. **Implement:** Assign M365 E3/E5 or Business Premium; add MDE for richer reporting.

2.2 Microsoft Defender Antivirus active

Description: Defender Antivirus is the active AV with real-time protection on. **Why:** ASR rules are enforced by Defender AV; they do nothing if Defender is disabled/passive. **Verify:** `Get-MpComputerStatus` (`AMRunning`, `RealTimeProtectionEnabled`); run `ASR-Discovery.ps1`. **Implement:** Ensure Defender AV is active (not passive/third-party-only); enable real-time protection.

2.3 Supported Windows OS

Description: Windows 10 1709+/Windows 11. **Why:** ASR rules require a supported Defender platform. **Verify:** `winver`. **Implement:** Patch/upgrade to a supported build; keep the Defender platform current.

2.4 Device enrollment

Description: Devices enrolled in Intune. **Why:** The ASR policy applies only to enrolled devices. **Verify:** Intune → **Devices** → **All devices**. **Implement:** Enable automatic enrollment; enroll devices.

2.5 (Recommended) Defender for Endpoint onboarding

Description: Devices onboarded to MDE. **Why:** Centralized ASR rule reports and advanced hunting come from MDE. **Verify:** Intune → **Endpoint security** → **Microsoft Defender for Endpoint**. **Implement:** Deploy the **Defender for Endpoint Integration** solution.

2.6 Application inventory (for exclusions)

Description: Awareness of legitimate apps that may trip a rule. **Why:** Audit mode reveals them; you exclude them before moving to Block. **Verify:** Review `ASR-AuditReport.ps1` output during the audit phase. **Implement:** Maintain an exclusions list per rule as needed.

Checklist

- Intune licensing assigned
- Defender AV active + real-time protection on — `ASR-Discovery.ps1`
- Supported Windows build
- Devices enrolled
- (Recommended) MDE onboarded for reporting
- Pilot Entra group created

Global Requirements — Intune Solutions (category-level)

These requirements apply to **every** solution in the **Intune Solutions** category. They are published once at the category level so individual listings stay small. Confirm these before deploying *any* Intune solution. Each entry: **Description · Why · Verify · Implement-if-missing.**

G1. Microsoft Entra ID tenant

Description: An active Microsoft Entra ID (Azure AD) tenant. **Why:** It is the identity backbone for every cloud and Intune-managed resource. **Verify:** Sign in to `https://entra.microsoft.com` as an administrator. **Implement:** Create a Microsoft 365/Azure subscription, which provisions a tenant.

G2. Microsoft Intune subscription

Description: An Intune-bearing license plan. **Why:** Intune delivers all configuration, compliance, and security policies. **Verify:** `https://intune.microsoft.com` loads; **Tenant administration** → **Tenant status** shows active. **Implement:** Assign Microsoft 365 E3/E5, Business Premium, or standalone Intune Plan 1.

G3. Administrative roles

Description: Appropriate Entra/Intune admin roles for the operator. **Why:** Creating policies and enrollment settings requires elevated rights. **Verify:** Entra → **Roles and administrators**; confirm **Intune Administrator**. **Implement:** Assign **Intune Administrator**; reserve Global Administrator for tenant-wide changes.

G4. Device enrollment in Intune

Description: Targeted Windows devices are enrolled and manageable. **Why:** Policies only reach enrolled devices. **Verify:** Intune → **Devices** → **All devices**; the device appears and is **compliant**. **Implement:** Enable **Automatic Enrollment** and join devices to Entra ID.

G5. Pilot security group

Description: A Microsoft Entra security group for pilot/targeted users or devices. **Why:** Every solution is piloted before fleet rollout. **Verify:** Entra → **Groups**; the pilot group exists. **Implement:** Entra → **Groups** → **New group** → **Security** → add members.

G6. Supported Windows baseline

Description: Windows 10 21H2+ or Windows 11 with current updates. **Why:** Modern Intune features assume a patched, supported OS. **Verify:** `winver`, or Intune → device → **Hardware**. **Implement:** Deploy **Update rings** or upgrade to Windows 11.

G7. Network access to Microsoft cloud endpoints

Description: Outbound HTTPS to Microsoft 365, Entra, and Intune service URLs. **Why:** Enrollment, policy sync, and authentication depend on these endpoints. **Verify:** From a device, reach `https://login.microsoftonline.com` and `https://enrollment.manage.microsoft.com`. **Implement:** Allow Microsoft's published Office 365/Intune URL & IP ranges through proxy/firewall.

The standard deployment model (all solutions): Assess → Configure → Pilot → Validate → Expand.

3. Implementation Guide — Attack Surface Reduction (ASR) Rules

Follow these steps **in order**, in the **Microsoft Intune admin center** (`https://intune.microsoft.com`).

> ***Model:** Deploy the high-value rules in **Audit** → review → exclude → switch to **Block** → expand.*

Step 1 — Create the pilot group

1. Entra → **Groups** → **New group** → Security → `ASR-Pilot` → add pilot devices. **Create**.

Step 2 — Create the ASR policy (Audit mode)

1. Intune → **Endpoint security** → **Attack surface reduction** → **Create Policy**.
2. **Platform:** Windows. **Profile: Attack Surface Reduction Rules**. **Create**.
3. **Name:** `ASR - Rules - Audit (Pilot)`. **Next**.

Step 3 — Set the rules to Audit

On **Configuration settings**, set these to **Audit**:

1. **Block all Office applications from creating child processes** → Audit.
2. **Block credential stealing from the Windows local security authority subsystem (lsass.exe)** → Audit.
3. **Block executable content from email client and webmail** → Audit.
4. **Block execution of potentially obfuscated scripts** → Audit.
5. **Block Office applications from injecting code into other processes** → Audit.
6. **Block Win32 API calls from Office macros** → Audit.
7. **Block process creations originating from PSExec and WMI commands** → Audit.
8. **Use advanced protection against ransomware** → Audit.

Click **Next**.

Step 4 — Assign and run the audit

1. **Assignments** → **Add groups** → `ASR-Pilot`. **Next** → **Create**.
2. Let pilot devices run normally for **1–2 weeks**.

Step 5 — Review audit events

1. On pilot devices run `ASR-AuditReport.ps1` (reads Defender ASR audit events), and review the **Attack surface reduction rules report** (Defender portal, if onboarded).
2. Identify legitimate apps that *would* have been blocked.

Step 6 — Add exclusions

1. Edit the ASR policy → for each rule with false positives, add **ASR Only Per Rule Exclusions** (or global ASR exclusions) for the verified legitimate file/path. **Save**.

Step 7 — Switch proven rules to Block

1. Duplicate the policy as `ASR - Rules - Block (Pilot)` (or edit) and change the validated rules from **Audit** to **Block**. Keep any still-noisy rule in Audit. **Save**.
2. Re-validate with `ASR-Validation.ps1`.

Step 8 — Expand to production

1. Add a production group to the **Block** policy **Assignments**; roll out in waves, watching the ASR report.
2. Re-run audit for any new rule before blocking it fleet-wide.
3. Re-validate each wave with `ASR-Validation.ps1` / `ASR-AuditReport.ps1`.

Order of operations

`Pilot group → ASR policy (Audit) → Assign → Review audit → Exclusions → Block → Expand`

5. Testing Guide — Attack Surface Reduction (ASR) Rules

Run during the audit phase (Implementation Step 5) and after switching rules to Block.

Test 1 — Policy applied

Do: Intune → **Endpoint security** → **Attack surface reduction** → policy → **Device status**. **Expected:** Pilot devices show **Succeeded**.

Test 2 — Rules are in the expected mode

Do: On a pilot device run `ASR-Validation.ps1` (reads the active rule IDs/actions). **Expected:** Each configured rule shows the expected mode (Audit during pilot; Block after enforcement).

Test 3 — Audit events are generated

Do: Trigger a benign test of a rule (e.g. an Office macro spawning a child process on a test doc), then run `ASR-AuditReport.ps1`. **Expected:** A corresponding **Audit** event (ID 1122) appears — proving the rule is evaluating.

Test 4 — Block enforces (after switching)

Do: With a rule in **Block**, repeat the benign test. **Expected:** The behavior is **blocked** (event ID 1121); the action is prevented.

Test 5 — Exclusions work

Do: For an excluded legitimate app, perform its normal action. **Expected:** The app runs without being blocked; the exclusion is honored.

Test 6 — No business-app breakage

Do: Have pilot users run core line-of-business apps with rules in Block. **Expected:** No legitimate app is blocked (any that is gets an exclusion before fleet rollout).

Test 7 — Report review

Do: Defender portal → **Reports** → **Attack surface reduction rules** (if MDE onboarded), or `ASR-AuditReport.ps1`. **Expected:** A clear audit/block event summary you can act on.

Pass/fail gate

Gate	Requirement
Audit pass	Tests 1–3 pass; false positives identified and excluded
Block pass	Tests 2, 4–6 pass; no legitimate app blocked

6. Troubleshooting Guide — Attack Surface Reduction (ASR) Rules

Use `ASR-Validation.ps1` / `ASR-Discovery.ps1` for rule state and `ASR-AuditReport.ps1` for events, `ASR-Remediation.ps1` for safe fixes.

A. Rules not taking effect

Symptom	Cause	Remediation
No audit/block events	Defender AV not active, or real-time protection off	Run `ASR-Discovery.ps1`; ensure Defender AV active + RTP on (`ASR-Remediation.ps1`)
Rule shows "Not configured" on device	Policy not applied / not synced	`ASR-Remediation.ps1` (sync); confirm device in `ASR-Pilot`
Defender in passive mode	A third-party AV is primary	ASR needs Defender active; with MDE, enable EDR-in-block mode or make Defender active

B. Legitimate app blocked

Symptom	Cause	Remediation
A business app stops working after Block	A rule blocks its (legitimate) behavior	Identify via `ASR-AuditReport.ps1` (event 1121); add a **per-rule exclusion** for the verified file/path; re-test
Same app trips multiple rules	Behavior matches several rules	Add the exclusion to each affected rule (or a global ASR exclusion)

C. Audit shows nothing during pilot

• Users didn't exercise the risky behaviors → ASR only logs when a matching behavior occurs. Run a benign rule test (e.g. controlled macro child-process), then re-check `ASR-AuditReport.ps1`.

• Wrong log → ASR events are in **Microsoft-Windows-Windows Defender/Operational** (IDs 1121 block, 1122 audit, 5007 config change).

D. Conflicts with other policies/baseline

• ASR also appears in the security baseline → manage ASR in **one** place. If you use this dedicated solution, don't also set ASR in the baseline (and vice-versa). Check with the Baselines solution's `ESB-ConflictCheck.ps1`.

E. Diagnostics quick reference

```
(Get-MpPreference).AttackSurfaceReductionRules_Ids      # configured rule GUIDs
(Get-MpPreference).AttackSurfaceReductionRules_Actions  # matching actions (0=Off,1=Block,2=Audit,6=Warn)
Get-MpComputerStatus | Select AMRunning, RealTimeProtectionEnabled
# audit/block events:
Get-WinEvent -LogName 'Microsoft-Windows-Windows Defender/Operational' | Where-Object Id -in 1121,1122
```

Run ASR`-RuleReference.ps1` to map GUIDs to friendly rule names.

F. When to escalate

If Defender is active, the policy shows Succeeded, rules are configured (ASR`-Validation.ps1`), and a legitimate app is still blocked with an exclusion in place, capture the 1121 event detail and open a Microsoft Defender support case.

7. Best Practices — Attack Surface Reduction (ASR) Rules

• **Always Audit first.** Deploy every rule in Audit, review events for 1–2 weeks, then move to Block. This is the single best way to avoid breaking business apps.

• **Start with the high-value rules.** Office child processes, LSASS credential theft, executable content from email, obfuscated scripts, and ransomware protection give the most security per unit of risk.

• **Exclude precisely.** Use per-rule exclusions scoped to the verified file/path — avoid broad global exclusions that weaken protection.

• **Manage ASR in one place.** Use this dedicated solution OR the security baseline for ASR — never both — to prevent conflicts.

• **Keep Defender AV active.** ASR does nothing in passive mode; ensure real-time protection is on.

• **Onboard to Defender for Endpoint.** It gives centralized ASR reporting and advanced hunting across the fleet.

• **Roll out by waves.** Move from pilot to production gradually, re-auditing any newly added rule before blocking fleet-wide.

• **Review events regularly.** ASR`-AuditReport.ps1` (and the Defender ASR report) catch both attacks and false positives.

• **Document exclusions.** Record each exclusion, the rule, and the business justification for audits.

• **Re-audit after major app changes.** New line-of-business software can trip rules; audit before enforcing on it.

8. Deliverables Summary — Attack Surface Reduction (ASR) Rules

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box
1. Solution Overview	What ASR rules block, rule modes, the high-value rules, benefits, limitations
2. Requirements Guide	Every prerequisite with Verify / Implement-if-missing
Global Requirements (Intune Solutions)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered Intune steps — Audit-first, exclusions, then Block
5. Testing Guide	Validation procedures with pass/fail gates
6. Troubleshooting Guide	Field issues and exclusion handling
7. Best Practices	Field-proven recommendations

PowerShell scripts

Script	What it does
`ASR-Discovery.ps1`	Defender AV state and the device's current ASR rule configuration
`ASR-Validation.ps1`	Confirms each configured rule is in the expected mode (Audit/Block)
`ASR-AuditReport.ps1`	Parses Defender ASR audit/block events (1121/1122) for review
`ASR-Remediation.ps1`	Safe remediation; ensures Defender AV active and forces a sync
`ASR-RuleReference.ps1`	Prints the ASR rule GUID → friendly-name map for reference

What the buyer receives

- This implementation guide as a branded **Word** document and **PDF**.
- All five **PowerShell scripts** in a single ZIP.
- A repeatable process following the repeatable model: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand.**

Outcome

Behavior-based malware prevention across the fleet — rolled out without breaking line-of-business apps.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

ASR-AuditReport.ps1

ASR-Discovery.ps1

ASR-Remediation.ps1

ASR-RuleReference.ps1

ASR-Validation.ps1